

Question Bank Part-1

Multiple Choice Questions (with Answers)

According to the document, what is the primary reason for the increasing need for security in modern systems?

- a) Decreased reliance on the internet
- b) Evolution of technology focused on ease of use, moving away from security
- c) Increased physical security mechanisms
- d) Lack of security standards

Answer: b) Evolution of technology focused on ease of use, moving away from security

The "CIA Triad" in security refers to:

- a) Confidentiality, Integrity, Availability
- b) Central Intelligence Agency
- c) Control, Integration, Access
- d) Confidentiality, Inspection, Authentication

Answer: a) Confidentiality, Integrity, Availability

Which of the following is an example of a passive attack?

- a) Modifying a data file
- b) Denial of Service
- c) Replaying a message
- d) Traffic analysis

Answer: d) Traffic analysis

The security service that ensures that a sender cannot deny having sent a message is:

- a) Authentication
- b) Data Integrity
- c) Non-Repudiation
- d) Access Control

Answer: c) Non-Repudiation

What is a "threat" in the context of security?

- a) A weakness in the system design
- b) An action that violates vulnerability
- c) A potential violation of security
- d) A security control mechanism

Answer: c) A potential violation of security

The security mechanism that involves "something you have and something you know" is an example of:

- a) Least Common Mechanism
- b) Separation of Privilege
- c) Psychological Acceptability
- d) Complete Mediation

Answer: b) Separation of Privilege

Question Bank Part-1

The principle of "Least Privilege" means that:

- a) Users should be frequently astonished by security measures.
- b) Users and processes should have the minimum privileges necessary.
- c) Security mechanisms should be as complex as possible.
- d) All users should share common resources.

Answer: b) Users and processes should have the minimum privileges necessary.

Which security mechanism is designed to detect, prevent, or recover from a security attack?

- a) Security Service
- b) Security Attack
- c) Security Mechanism
- d) Security Architecture

Answer: c) Security Mechanism

The concept of "Defense in Depth" is also known as:

- a) Economy of Mechanism
- b) Layering
- c) Isolation
- d) Encapsulation

Answer: b) Layering

Which of the following is a "pervasive" security mechanism?

- a) Digital Signatures
- b) Encryption
- c) Security Audit Trails
- d) Access Controls

Answer: c) Security Audit Trails

The principle that aims to make security user-friendly and not disruptive is:

- a) Least Astonishment
- b) Psychological Acceptability
- c) Complete Mediation
- d) Modularity

Answer: b) Psychological Acceptability

In the Network Security Model, what is the role of the "Trusted Third Party"?

- a) To act as an opponent
- b) To distribute secret information
- c) To alter messages in transit
- d) To monitor traffic passively

Answer: b) To distribute secret information

"Fabrication" of a message is an attack on:

- a) Confidentiality

Question Bank Part-1

- b) Integrity
- c) Availability
- d) Authenticity

Answer: d) Authenticity

Why is "Complete Mediation" challenging to implement fully?

- a) It is too simple for modern systems.
- b) It requires checking permissions for every access, which is resource-intensive.
- c) Users find it too easy to understand.
- d) It relies on secret algorithms.

Answer: b) It requires checking permissions for every access, which is resource-intensive.

According to the document, what is the most difficult challenge in cybersecurity?

- a) Lack of user education
- b) The ever-evolving nature of security risks
- c) Inadequate physical security
- d) High cost of implementation

Answer: b) The ever-evolving nature of security risks

The core duty of cybersecurity is to identify, mitigate, and manage what?

- a) Cyber Threats
- b) Cyber Warfare
- c) Cyberrisk
- d) Vulnerabilities

Answer: c) Cyberrisk

Which approach to cybersecurity relies on regulations or standards to determine security implementations, often leading to a "checkbox" attitude?

- a) Risk-based
- b) Ad hoc
- c) Compliance-based
- d) Modular-based

Answer: c) Compliance-based

In risk management, what is the term for "the remaining risk after management has implemented a risk response"?

- a) Inherent Risk
- b) Residual Risk
- c) Vulnerable Risk
- d) Threat Risk

Answer: b) Residual Risk

How does the document define a "Cracker"?

- a) A good person who hacks for knowledge

Question Bank Part-1

- b) An ethical professional who protects data
- c) An evil person who breaks into a system for benefits
- d) A person who creates new security tools

Answer: c) An evil person who breaks into a system for benefits

A hacker who acts without malicious intent but without the owner's permission to expose a weakness is known as a:

- a) Black Hat Hacker
- b) White Hat Hacker
- c) Grey Hat Hacker
- d) Script Kiddie

Answer: c) Grey Hat Hacker

Which threat agent is characterized by their willingness to use violence and frequently targets critical infrastructures?

- a) Hacktivists
- b) Cybercriminals
- c) Cyberterrorists
- d) Nation States

Answer: c) Cyberterrorists

What type of attack results from inserting malicious code into a server that uses SQL?

- a) Phishing Attack
- b) Drive-by Download
- c) SQL Injection
- d) Man-in-the-Middle Attack

Answer: c) SQL Injection

Which of the following is NOT listed as a critical infrastructure sector?

- a) Dams
- b) Social Media
- c) Financial Services
- d) Energy

Answer: b) Social Media

What is a "Script Kiddie"?

- a) A non-expert who uses pre-packaged tools to break into systems
- b) A highly skilled programmer who finds software vulnerabilities
- c) A hacker motivated by political ideology
- d) A security professional who tests systems for bugs

Answer: a) A non-expert who uses pre-packaged tools to break into systems

Which term is defined as "Something of either tangible or intangible value that is worth protecting"?

- a) Threat

Question Bank Part-1

b) Vulnerability

c) Asset

d) Risk

Answer: c) Asset

What is the main motivation for Cybercriminals, according to the document?

a) Political ideology

b) Desire for profit

c) National security

d) Learning and curiosity

Answer: b) Desire for profit

Which function of the cybersecurity framework involves "planning for resilience and the timely repair of compromised capabilities"?

a) Protect

b) Detect

c) Respond

d) Recover

Answer: d) Recover

In which stage of the Cyber Kill Chain does an attacker gather information using methods like social media research and network scanning?

a) Weaponization

b) Delivery

c) Reconnaissance

d) Exploitation

Answer: c) Reconnaissance

What is the primary goal of the "Weaponization" stage?

a) To deliver the payload to the target

b) To establish a remote command channel

c) To pair an exploit with a delivery mechanism

d) To execute the attack's final objective

Answer: c) To pair an exploit with a delivery mechanism

Spear-phishing emails are most commonly associated with which stage of the Cyber Kill Chain?

a) Installation

b) Delivery

c) Actions on Objectives

d) Command and Control

Answer: b) Delivery

The term "zero-day" is most directly associated with which stage?

a) Reconnaissance

Question Bank Part-1

- b) Weaponization
- c) Exploitation
- d) Installation

Answer: c) Exploitation

What is the main purpose of the "Installation" stage?

- a) To gather target information
- b) To create a persistent foothold on the victim's system
- c) To encrypt data for ransom
- d) To establish a remote command channel

Answer: b) To create a persistent foothold on the victim's system

The final phase of the Cyber Kill Chain, where the attacker achieves their primary goal, is called:

- a) Command and Control
- b) Exploitation
- c) Actions on Objectives
- d) Delivery

Answer: c) Actions on Objectives

According to the document, what is a key benefit of using the Cyber Kill Chain framework?

- a) It automatically removes all malware from a network.
- b) Interrupting an attack at any step can reduce the risk and impact of cyber threats.
- c) It guarantees prevention of all phishing attacks.
- d) It focuses solely on physical security measures.

Answer: b) Interrupting an attack at any step can reduce the risk and impact of cyber threats.

Which of the following activities would typically occur in the "Actions on Objectives" stage?

- a) Sending a weaponized email attachment
- b) Scanning for open ports on a target network
- c) Data exfiltration or deploying ransomware
- d) Pairing a backdoor with an exploit

Answer: c) Data exfiltration or deploying ransomware

What is the main objective of malware, as defined in the document?

- a) To improve computer performance
- b) To gain unauthorized access, steal information, or disrupt operations
- c) To automatically update software
- d) To create backups of user data

Answer: b) To gain unauthorized access, steal information, or disrupt operations

Which type of malware gains access to a system by hiding within a genuine application?

- a) Virus
- b) Trojan Horse
- c) Rootkit

Question Bank Part-1

d) Scareware

Answer: b) Trojan Horse

What is the key distinguishing feature of a Network Worm?

a) It requires user interaction to spread.

b) It is a form of advertising software.

c) It is a self-replicating code that spreads across networks without user intervention.

d) It hides the existence of other malware.

Answer: c) It is a self-replicating code that spreads across networks without user intervention.

Which malware is described as one of the "nastiest forms" that hides its presence and gains administrator-level privileges?

a) Browser Hijacker

b) Scareware

c) Rootkit

d) Virus

Answer: c) Rootkit

What is the primary goal of Scareware?

a) To improve internet speed

b) To encrypt user files for ransom

c) To trick users into buying fake products or stealing their information

d) To record user keystrokes

Answer: c) To trick users into buying fake products or stealing their information

An attack that floods a service with requests from a single source to overwhelm it is a:

a) Man-in-the-Middle (MITM) Attack

b) Denial-of-Service (DoS) Attack

c) Brute Force Attack

d) SQL Injection Attack

Answer: b) Denial-of-Service (DoS) Attack

The main difference between a DoS and a DDoS attack is that a DDoS attack:

a) Is less dangerous

b) Uses multiple sources to generate attack traffic

c) Only targets DNS servers

d) Is easier to prevent

Answer: b) Uses multiple sources to generate attack traffic

In a Man-in-the-Middle (MITM) attack, what does the attacker do?

a) Guesses passwords repeatedly

b) Injects malicious scripts into a website

c) Intercepts and potentially alters communication between two parties

Question Bank Part-1

d) Overflows a buffer with data

Answer: c) Intercepts and potentially alters communication between two parties

What type of attack uses specially crafted emails to masquerade as a trusted party to obtain sensitive information?

a) Brute Force Attack

b) Zero-day Exploit

c) Spear Phishing

d) Buffer Overflow

Answer: c) Spear Phishing

An attack that results from inserting malicious SQL code into a web application's input field is called:

a) Cross-site Scripting (XSS)

b) SQL Injection

c) Spoofing

d) Keylogging

Answer: b) SQL Injection

A vulnerability that is exploited before the software vendor is aware of it is known as a:

a) Botnet

b) Zero-day Exploit

c) Backdoor

d) Scareware

Answer: b) Zero-day Exploit

Which of the following is a technique used in a Brute Force Attack?

a) Intercepting communication

b) Trying all possible password combinations

c) Sending phishing emails

d) Exploiting an unknown software flaw

Answer: b) Trying all possible password combinations

What type of malware secretly records user keystrokes?

a) Adware

b) Keylogger

c) Ransomware

d) Browser Hijacker

Answer: b) Keylogger

The main objective of a Browser Hijacker is to:

a) Encrypt user files

b) Force users to visit specific websites to generate traffic and revenue

c) Create a backdoor for remote access

Question Bank Part-1

d) Slow down the computer's CPU

Answer: b) Force users to visit specific websites to generate traffic and revenue

Faking the sending address of a transmission to gain illegal entry into a secure system is called:

a) Phishing

b) Spoofing

c) Sniffing

d) Hijacking

Answer: b) Spoofing

Which attack involves an attacker injecting malicious scripts into a trusted website?

a) SQL Injection

b) Cross-site Scripting (XSS)

c) Denial-of-Service (DoS)

d) Man-in-the-Middle (MITM)

Answer: b) Cross-site Scripting (XSS)

True/False Questions (with Answers)

A passive attack does not affect system resources.

Answer: True

The "Fail-Safe Default" principle suggests that the default state should be to grant access.

Answer: False

The principle of "Economy of Mechanism" encourages complex and large security designs.

Answer: False

"Non-Repudiation" is a security service that prevents denial of service attacks.

Answer: False (It prevents a party from denying an action.)

"Least Common Mechanism" aims to maximize the number of shared resources between users.

Answer: False

The "Least Privilege" principle can be implemented using Role-Based Access Control (RBAC).

Answer: True

The "Psychological Acceptability" principle states that security should be as complex as possible to deter hackers.

Answer: False

The "Isolation Principle" only applies to physical separation and not logical separation.

Answer: False

"Encapsulation" in security restricts access to data through controlled entry points.

Answer: True

Question Bank Part-1

The "Least Astonishment" principle means a system should behave in surprising ways to keep users alert.

Answer: False

Cyberspace includes only hardware and software, not people or social interactions.

Answer: False

A Distributed Denial of Service (DDoS) attack aims to disrupt a network by flooding it with superfluous requests.

Answer: True

A zero-day exploit is a flaw in software that is well-known and already patched by the vendor.

Answer: False

Cyber terrorism is defined as any premeditated, politically motivated attack against information systems that threatens violence.

Answer: True

The "Ad hoc" approach to cybersecurity is considered the most effective and rational method.

Answer: False

In risk management, a "threat" and a "vulnerability" mean the same thing.

Answer: False

White Hat Hackers are also known as Ethical Hackers and their activities are legal.

Answer: True

The "Recover" function in cybersecurity frameworks happens before the "Detect" function.

Answer: False

Intellectual Property Theft is a type of cyber threat that involves stealing or using someone else's intellectual property without permission.

Answer: True

A vulnerability is a weakness in the design or implementation of a process that could expose the system to threats.

Answer: True

The "Compliance-based" security approach is also known as risk-based security.

Answer: False

A Blue Hat Hacker is typically someone used to bug-test a system prior to its launch.

Answer: True

Third-party risk is not a significant concern in cybersecurity.

Answer: False

Cyber warfare can only be conducted by nation-states, not by terrorist groups.

Answer: False

Question Bank Part-1

A hacktivist uses technology to announce a social, ideological, religious, or political message.

Answer: True

The cost of cybercrime for an organization only includes external expenses like fines.

Answer: False (It also includes many internal costs like detection, investigation, and recovery.)

According to the document, cyber crime is massively over-reported.

Answer: False

The Cyber Kill Chain framework breaks down a cyber attack into five distinct stages.

Answer: False

Reconnaissance can involve both passive (like OSINT) and active (like port scans) methods.

Answer: True

The primary goal of the "Command and Control" stage is to steal data immediately.

Answer: False

Installing malware that survives a system reboot is part of the "Installation" stage.

Answer: True

The Cyber Kill Chain states that an attack can only be stopped during the Reconnaissance phase.

Answer: False

DNS tunneling is a technique that can be used in the "Command and Control" stage.

Answer: True

"Lateral movement" across systems typically occurs in the "Weaponization" stage.

Answer: False

The "Delivery" stage is where an attacker pairs an exploit with a backdoor into a payload.

Answer: False

Spyware is designed to monitor a user's online activities and habits without their knowledge.

Answer: True

A rootkit is easy to detect and remove once it infects a system.

Answer: False

Scareware displays fake warnings about non-existent threats to trick users.

Answer: True

A Brute Force Attack is characterized by its high speed and low resource consumption.

Answer: False

Social engineering attacks exploit technical vulnerabilities in software code.

Answer: False

Question Bank Part-1

Phishing and Spear Phishing are identical attacks with no differences.

Answer: False

SQL Injection attacks target vulnerabilities in a website's database query handling.

Answer: True

Botnets can be used to carry out Distributed Denial-of-Service (DDoS) attacks.

Answer: True

The primary purpose of Adware is to encrypt user data and demand a ransom.

Answer: False

A keylogger is a type of malware that can record screen content and audio in addition to keystrokes.

Answer: True

A Man-in-the-Middle (MITM) attack can involve email hijacking and SSL hijacking.

Answer: True

A worm requires user interaction to spread from one computer to another.

Answer: False

The term "Backdoor" refers to a means of regaining access to a compromised system.

Answer: True

Compare and Define Questions (short Answers)

1. Define cybersecurity and explain its primary goals.
2. What are the three key principles of CIA Triad?
3. Compare white-hat hackers and black-hat hackers.
4. Explain the concept of social engineering with an example.
5. Define malware and list its major categories.
6. Differentiate between worms and viruses.
7. Explain what a Trojan horse is in cybersecurity.
8. Compare DoS and DDoS attacks.
9. Explain SQL Injection with an example.
10. Define phishing and describe how it works.
11. Compare: Hacker vs Cracker
12. Define: Ransomware
13. Compare: Virus vs Worm

Question Bank Part-1

- 14. Define: Rootkit
- 15. Compare: White Hat vs Black Hat Hacker
- 16. Compare: Firewall vs Antivirus
- 17. Compare: Social Engineering vs Phishing
- 18. Compare: Trojan Horse vs Spyware
- 19. Compare: DoS vs DDoS Attack
- 20. Define: SQL Injection
- 21. Compare: Application Security vs Network Security
- 22. Define: Brute Force Attack
- 23. Compare: Scareware vs Ransomware
- 24. Compare: Threat vs Vulnerability
- 25. Define: Spoofing